

Incident Response Plan (IRP)

Master plan for security incident handling — NIST SP 800-61 aligned

Document ID: BVT-IRP-045

Version: 1.0

Issued: July 02, 2026

Effective Date: _____

Purpose and Activation

This plan governs response to security incidents affecting BVTech or its managed clients. An "incident" is any event that jeopardizes the confidentiality, integrity, or availability of systems or data (e.g., malware, account compromise, ransomware, data exposure, insider misuse). Anyone may report a suspected incident; the on-call engineer performs initial triage and the Incident Commander (Managing Partner or designee) formally declares incidents of severity SEV-2 or higher.

Severity Levels

Severity	Definition	Examples	Initial Response
SEV-1	Active, spreading, or business-critical compromise	Ransomware detonation; domain admin compromise; active data exfiltration	Immediate, 24x7; all-hands
SEV-2	Confirmed compromise, contained scope	Single compromised mailbox; malware quarantined but persistence suspected	Within 1 hour
SEV-3	Suspicious activity requiring investigation	Credential phishing click, unusual sign-in, policy violation	Within 4 business hours

Roles

Role	Responsibilities
Incident Commander (IC)	Declares/closes incidents, directs response, approves containment with business impact, owns communications decisions
Lead Responder	Technical investigation, containment, eradication, evidence handling
Scribe	Timeline log: every action, time (CT), and actor — contemporaneous notes are critical
Client Liaison	Single voice to the affected client; no other responder communicates externally
Counsel / Insurer (external)	Engaged for SEV-1 and any suspected personal-data breach before notification decisions

Response Lifecycle

- 1 DETECT & TRIAGE — Validate the alert/report; assign severity; open incident ticket; start the timeline log; preserve volatile evidence before rebooting anything.

- 2 **CONTAIN** — Short-term: isolate affected endpoints (EDR network isolation), disable compromised accounts, revoke sessions/tokens, block indicators. Long-term: segment, reset credentials in scope, harden entry vector. Do NOT power off systems suspected of ransomware staging unless encryption is actively in progress — isolate instead to preserve memory evidence.
- 3 **ERADICATE** — Remove malware/persistence (scheduled tasks, run keys, rogue OAuth apps, forwarding rules, rogue MFA methods); identify root cause; verify with fresh scans.
- 4 **RECOVER** — Restore from known-good backups where integrity is in doubt; rebuild rather than clean when compromise depth is uncertain; staged return to production with heightened monitoring for 30 days.
- 5 **POST-INCIDENT** — Within 5 business days hold a blameless review; complete the Incident Report (BVT-IRP-048); update controls, playbooks, and the risk register; track corrective actions to closure.

Evidence Handling

- Preserve: EDR telemetry, relevant logs (export before rotation), disk/memory images for SEV-1 where forensics may be needed, phishing emails with full headers.
- Chain of custody: record who collected what, when, and where it is stored; store evidence in Restricted-classified storage.
- If litigation or law enforcement involvement is plausible, coordinate preservation with counsel before altering systems.

Communications

- Internal: incident channel only; need-to-know; assume compromised email may be monitored by the attacker — use out-of-band channels for SEV-1 credential resets.
- Client: IC-approved factual updates at agreed cadence (SEV-1: at least every 4 hours until contained).
- External/regulatory/notification decisions: only with counsel per the Breach Notification Procedure (BVT-IRP-052). No public statements without IC approval.
- Law enforcement: report significant incidents to the FBI IC3 / local field office as advised by counsel.

Plan Maintenance

Reviewed annually and after every SEV-1/SEV-2 incident. A tabletop exercise is conducted at least annually using a current playbook scenario. Contact rosters are verified quarterly.